Introducción a las vulnerabilidades

PID_00274038

Carlos Fouz

Tiempo mínimo de dedicación recomendado: 3 horas



Universitat Oberta de Catalunya

Carlos Fouz

Máster universitario en Seguridad de las Tecnologías de la Información y de las Comunicaciones con más de diez años de experiencia en seguridad informática e informática forense. Actualmente trabaja como a perito informático para la Administración pública.

El encargo y la creación de este recurso de aprendizaje UOC han sido coordinados por la profesora: Helena Rifà

Primera edición: febrero 2021
© de esta edición, Fundació Universitat Oberta de Catalunya (FUOC)
Av. Tibidabo, 39-43, 08035 Barcelona
Autoría: Carlos Fouz
Producción: FUOC
Todos los derechos reservados

Ninguna parte de esta publicación, incluido el diseño general y la cubierta, puede ser copiada, reproducida, almacenada o transmitida de ninguna forma, ni por ningún medio, sea este eléctrico, mecánico, óptico, grabación, fotocopia, o cualquier otro, sin la previa autorización escrita del titular de los derechos.

Índice

Introducción..... 5

Objetivos..... 6

1. Concepto de vulnerabilidad..... 7
1.1. Diferentes actores que intervienen en la detección y el análisis de vulnerabilidades 7
1.1.1. Fabricantes de hardware 8
1.1.2. Fabricantes de software 8
1.1.3. Empresas que ofrecen servicios de seguridad 9
1.1.4. Entidades gubernamentales o asociaciones sin ánimo de lucro 10
1.1.5. Expertos en seguridad informática 13
1.1.6. Empresas y usuarios 14
1.2. Ejemplos de vulnerabilidades 14

2. Clasificación de las vulnerabilidades..... 17
2.1. Desconocidas o conocidas 17
2.1.1. Vulnerabilidades no conocidas (*día cero*) 17
2.1.2. Vulnerabilidades conocidas 18
2.2. Tipo de sistema afectado 18
2.2.1. Sistemas informáticos 18
2.2.2. Aplicaciones 20
2.2.3. Gestión de la información 24

3. Gestión de las vulnerabilidades..... 25

4. Análisis de las vulnerabilidades..... 29
4.1. Metodología 29
4.1.1. Metodología preventiva 29
4.1.2. Metodología reactiva 30
4.1.3. Metodologías de análisis de vulnerabilidades de aplicaciones o código malicioso 31
4.2. Mecanismos de evasión 33
4.3. Herramientas 33

Resumen..... 35

Glosario..... 37

Bibliografía..... 38

Introducción

En un mundo cada vez más conectado, donde las relaciones entre las personas, las organizaciones y los Gobiernos se realizan en formato digital mediante el uso de las tecnologías de la información y la comunicación (TIC), la seguridad de estos sistemas y su información forma parte esencial de nuestras actividades diarias.

Las organizaciones han iniciado una transformación digital añadiendo valor a la información de la que disponen para tomar ventajas competitivas, y donde la formación en herramientas TIC a sus trabajadores y las políticas de seguridad se han convertido en una prioridad. Asimismo, las empresas fabricantes de los productos cada vez destinan más recursos a mejorar la seguridad de sus herramientas, no solo añadiendo nuevas funcionalidades.

Como veremos este módulo, la gestión de las vulnerabilidades es un proceso continuo de identificación, clasificación y corrección que afecta a los sistemas de información y a las aplicaciones de las organizaciones, y existen diferentes actores implicados, con diversas tareas especializadas.

Objetivos

Los objetivos que el estudiante tiene que haber adquirido después de estudiar los contenidos de este módulo son los siguientes:

1. Entender el concepto de incidente de seguridad o **ataque informático**.
2. Entender el concepto de **vulnerabilidad** de seguridad en el ámbito informático y su contexto.
3. Conocer cómo se identifican y **clasifican** las vulnerabilidades.
4. Identificar los diferentes actores que intervienen en la **detección y el análisis** de vulnerabilidades, así como sus funciones.
5. Conocer cómo se **gestionan** las vulnerabilidades y cómo se analizan.

1. Concepto de vulnerabilidad

Para entender el concepto de vulnerabilidad informática, primero hemos de entender el concepto de incidente de seguridad o ataque informático.

Un **incidente de seguridad** o **ataque informático** es un acto intencionado y deliberado que intenta evadir las restricciones de seguridad de un sistema informático para sacar un provecho o realizar unos daños.

Un ejemplo de ataque informático podría ser la acción por parte de un atacante que realiza la compra de un producto a través de una página web y que deliberadamente aprovecha un error del sistema para evadir los sistemas de seguridad y no pagar el producto.

En este supuesto, el atacante aprovecharía una vulnerabilidad del sistema de pago de comercio electrónico para sacar un provecho. Este fallo del sistema de pago no tiene por qué ser técnico, sino que puede ser usando medios como la ingeniería social, que veremos más adelante.

De este modo, podemos definir una **vulnerabilidad de seguridad** como un fallo o debilidad que permite que una persona pueda evadir las restricciones de seguridad del sistema en el que se encuentra.

Las restricciones de seguridad de un sistema informático se denominan *políticas de seguridad* y gestionan la confidencialidad, la integridad, la disponibilidad, el control de acceso y la consistencia del sistema o sus datos.

1.1. Diferentes actores que intervienen en la detección y el análisis de vulnerabilidades

Una parte muy importante de la seguridad informática hoy en día es la detección, el análisis y la respuesta a incidentes de seguridad, que aprovechan vulnerabilidades del sistema para conseguir su objetivo.

Dentro de esta gestión de las vulnerabilidades e incidentes de seguridad intervienen varios agentes, que veremos a continuación.

1.1.1. Fabricantes de hardware

Los fabricantes de hardware son los responsables de actualizar el software que gestiona su hardware, denominado *firmware*. De este modo, si nuestro enrutador de casa que nos da acceso a internet tiene una vulnerabilidad conocida por su fabricante, el fabricante pondrá a nuestra disposición una actualización de su *firmware* para mitigar la vulnerabilidad conocida.

Lectura complementaria

Aviso de seguridad sobre Spectre: **INCIBE** (2018). «Problemas de seguridad en los procesadores de varios fabricantes» [avisos de seguridad en línea]. Madrid: Instituto Nacional de Ciberseguridad. https://www.incibe.es/protege-tu-empresa/avisos-seguridad/problemas-seguridad-los-procesadores-varios-fabricantes.

Por otro lado, no siempre se actualiza el *firmware* para arreglar un problema de seguridad, sino que también se actualiza para añadir funcionalidades o mejoras en la gestión o el uso del hardware.

Las vulnerabilidades de hardware y *firmware* son muy difíciles de detectar y reparar. En enero de 2018, dos investigadores de seguridad descubrieron la vulnerabilidad llamada Spectre, que afecta a la mayoría de los microprocesadores modernos, y que afectó a casi todos los sistemas informáticos, incluidos ordenadores de sobremesa, portátiles y dispositivos móviles.

1.1.2. Fabricantes de software

Los fabricantes de software, como por ejemplo Microsoft, van actualizando sus aplicaciones o sistemas operativos para añadir nuevas funcionalidades, pero también para reparar o resolver vulnerabilidades conocidas de sus productos.

Por esta razón, en el ámbito de la seguridad siempre es recomendable disponer de software original, que tiene acceso a las últimas actualizaciones de seguridad. Sería sorprendente que una empresa tuviera un gran volumen de negocio y que, por no disponer del paquete Microsoft Office actualizado, tuviera una vulnerabilidad que le provocara ser víctima de cualquier tipo de ataque *ransomware*[1] simplemente abriendo un documento de Microsoft Word.

(1)https://es.wikipedia.org/wiki/Ransomware

Aparte de software de gestión de la información o producción de la empresa, también hay software específicamente de seguridad, como pueden ser:

1) Antivirus. Software con el fin de evitar una infección por virus informáticos u otro código malicioso, como software espía (*spyware*), gusanos, troyanos, *rootkits*, etc.

Actualmente, los antivirus pueden identificar las infecciones mediante búsquedas de partes conocidas de los programas maliciosos o incluso controlando las actividades que realizan en el ordenador los programas cuando se ejecutan.

2) Cortafuegos (*firewall*). Software encargado de controlar las conexiones que recibe un ordenador, permitiéndolas o denegándolas en función de unas reglas.

Por ejemplo, el cortafuegos puede bloquear conexiones externas (internet) a nuestro ordenador para evitar que un atacante pueda aprovechar vulnerabilidades de nuestro equipo.

3) Servidor intermediario (*proxy*). Su funcionalidad principal es que todos los ordenadores de una red puedan acceder a internet mediante este servidor intermediario; así se puede monitorizar la navegación de los usuarios y aceptar o denegar el acceso a ciertas páginas de internet categorizadas como, por ejemplo, páginas de contenido adulto.

Se tiene que procurar conocer todo el software instalado en nuestro ordenador, y que esté actualizado con las últimas actualizaciones de seguridad.

1.1.3. Empresas que ofrecen servicios de seguridad

Dado que no todas las empresas pueden disponer de los recursos necesarios para velar por la detección y el análisis de las vulnerabilidades en sus sistemas, existen empresas que ofrecen ciertos servicios de seguridad a empresas o particulares.

Estas empresas ofrecen servicios como los siguientes:

1) Consultoría de gestión de la información. Consultoría con tareas relacionadas con la gestión de sistemas de información, mediante el conocimiento y los flujos de información de la organización empresarial. Aporta optimización de los procesos de gestión de la empresa y nuevas formas de organización, teniendo en cuenta tanto el aspecto tecnológico como el de gestión de recursos humanos. Asimismo, son recomendables en tareas de certificación o acreditación tipo ISO.

2) Pruebas de intrusión. Corresponden a la simulación de un ataque a un sistema informático con la intención de encontrar las debilidades de seguridad. Lo primero que se debe establecer es el alcance de las pruebas que se van a llevar a cabo y si la empresa que realiza las pruebas tiene algún tipo de acceso o conocimiento de la empresa auditada.

3) Monitorización de los sistemas con herramientas IDS, SIEM, SOC. Las herramientas de monitorización recopilan y analizan toda la actividad; permiten ver el estado de nuestro hardware y nuestros servicios para estar informados del estado y de la actividad de nuestra organización las 24 horas del día los 365 días del año.

A continuación, se muestran algunos ejemplos de herramientas de monitorización en función de su objetivo:

- **IDS (*intrusion detection system*)**. Un IDS, un sistema de detección de intrusos, analiza la actividad de red de la organización para detectar comportamientos anómalos y ataques o intrusiones usando patrones de ataques conocidos.

- **SIEM (*security information and event management*)**. Un SIEM es un software que almacena y analiza los datos de seguridad de diferentes sistemas de la organización, como aplicaciones antivirus, cortafuegos, *proxy*, IDS, *logs* de actividades de los servidores, *logs* de softwares, etc., con el objetivo de detectar y analizar amenazas de seguridad de los sistemas informáticos y de información de la organización. Asimismo, permite generar alertas con inteligencia computacional para gestionar de manera proactiva las potenciales vulnerabilidades.

- **SOC (*security operations center*)**. Un SOC, un centro de operaciones de seguridad, ofrece un servicio a diferentes empresas de las que centraliza y analiza datos de servidores, cortafuegos, sistemas de detección de intrusos, software antivirus y otros sistemas especializados. Estos centros de operaciones disponen de expertos certificados en estándares de seguridad que analizan los datos y las alertas para prestar distintos servicios que van desde el diagnóstico de vulnerabilidades hasta la recuperación de desastres, pasando por la respuesta a incidentes, neutralización de ataques, programas de prevención, administración de riesgos y alertas de antivirus informáticos.

4) Informática forense y respuesta a incidentes (DFIR, *digital forensics, incident response*). La informática forense es una rama de la ciencia forense que incluye la recuperación y la búsqueda de información de los dispositivos digitales, tanto para dar respuesta a incidentes de seguridad como para localizar las evidencias digitales relevantes para la investigación.

La persona responsable de llevar a cabo correctamente este procedimiento se denomina *perito informático*, y debe tener conocimientos sobre la metodología de investigación de incidentes para efectuar un informe pericial o dictamen válido en un proceso judicial.

1.1.4. Entidades gubernamentales o asociaciones sin ánimo de lucro

Existen diferentes entidades que se dedican a la difusión de vulnerabilidades y soluciones de ciberseguridad. A continuación se nombran algunas:

1) CSIRT (Computer Security Incidente Response Team). Un CSIRT, un equipo de respuesta a incidencias de seguridad informáticas, es un centro de respuesta a incidentes de seguridad en tecnologías de la información formado por expertos en la materia.

Enlace de interés

Listado global CERT/CSIRT: https://bit.ly/3jGQwaK.

Una de sus tareas principales consiste en publicar información como alertas relativas a amenazas y vulnerabilidades existentes, así como realizar un seguimiento de estas y publicar las medidas adecuadas para mitigarlas.

En Estados Unidos también se denominan CERT (Computer Emergency Response Team) y es normal ver las siglas CERT/CSIRT juntas.

Durante el año 2000 se creó una infraestructura de servicios por parte de todos los CSIRT europeos denominada TF-CSIRT Trusted Introducer, que enumera CSIRT conocidos y los acredita según su nivel de madurez demostrado y comprobado.

Según TF-CSIRT, en España disponemos de los siguientes CERT/CSIRT acreditados (figura 1).

Figura 1. Listado de CERT españoles acreditados

Spain	
AndaluciaCERT	Accredited (since 14 May 2018)
BCSC	Listed (since 05 Feb 2019)
Caixabank CSIRT	Accredited (since 13 Jul 2017)
CCN-CERT	Accredited (since 25 Jan 2008)
CERT-UC3M	Listed (since 22 Feb 2017)
CESICAT-CERT	Accredited (since 25 Dec 2010)
CSIRT.gal	Listed (since 29 Jun 2018)
CSIRTCV	Accredited (since 27 Sep 2011)
CSUC-CSIRT	Accredited (since 13 Jan 2015)
ENTELGY INNOTEC CSIRT	Accredited (since 14 Oct 2016)
ERIS-CERT	Accredited (since 25 Jun 2018)
esCERT-UPC	Accredited (since 30 Sep 2001)
ESP DEF CERT	Accredited (since 18 Jul 2013)
INCIBE-CERT	Accredited (since 01 Jul 2008)
ITS-CERT	Listed (since 07 Mar 2019)
ITXCSIRT	Listed (since 05 Feb 2019)
MAPFRE-CCG-CERT	Listed (since 18 Feb 2019)
Minsait CSIRT	Listed (since 14 May 2018)
NS-CERT	Accredited (since 20 Apr 2018)
RedIRIS	Accredited (since 23 Mar 2001)
S2 Grupo CERT	Accredited (since 19 Apr 2016)
S21sec CERT	Accredited (since 19 Sep 2011)

Fuente: TF-CSIRT.

Dentro de los CERT/CSIRT españoles, podemos destacar el Instituto Nacional de Ciberseguridad de España (INCIBE), anteriormente Instituto Nacional de Tecnologías de la Comunicación, que es una sociedad dependiente de la Secretaría de Estado del Ministerio de Economía y Empresa que trabaja como entidad de referencia para el desarrollo de la ciberseguridad y la confianza digital de los ciudadanos, de la red académica y de investigación, de los profesionales, de las empresas y especialmente de los sectores estratégicos.

Sus actividades principales se basan en la investigación, la prestación de servicios y la coordinación con los diferentes agentes que intervienen en la gestión de la ciberseguridad, y contribuye a la construcción de la ciberseguridad a escala nacional e internacional.

2) Bases de datos de vulnerabilidades. Existen multitud de bases de datos con información sobre vulnerabilidades conocidas, que son mantenidas por CERT/CSIRT, empresas privadas de seguridad o incluso fabricantes de software o hardware.

Normalmente se tienen que realizar búsquedas en cada base de datos en función del criterio que deseemos, pero también existen herramientas como *cvesearch* o *metaexploit* que se conectan a las bases de datos de vulnerabilidades conocidas a través de internet y nos permiten descargar la información de las vulnerabilidades publicadas para trabajar en local o de una manera más centralizada.

Aparte de las bases de datos de los CERT/CSIRT, destacamos las siguientes:

- **MITRE**. Es una organización adscrita al Gobierno de Estados Unidos que administra diferentes centros de investigación de seguridad y que cuenta con una gran base de datos de vulnerabilidades conocidas. Asimismo, MITRE es la organización que creó y que mantiene el sistema de identificación de vulnerabilidades más conocido y que se usa a nivel mundial, el llamado CVE (Common Vulnerabilities and Exposures).

- **Security Focus Vulnerability Database**. Base de datos mantenida desde 1999 que dispone de un servicio de distribución por correo electrónico (*mailing list*). Fue uno de los primeros canales de difusión de vulnerabilidades de la comunidad dedicada a la seguridad.

Ved también

Encontraréis más información sobre el CVE en el apartado 2 de este módulo.

1.1.5. Expertos en seguridad informática

Los expertos en seguridad informática disponen de varios canales para hacer públicas sus conclusiones, con el fin de obtener reconocimiento o una recompensa económica.

Destacamos los siguientes:

1) Bug bounty. Servicio que ofrecen organizaciones y fabricantes de hardware o software donde las personas que notifiquen una vulnerabilidad que afecta a su ámbito reciben un reconocimiento y una compensación económica en función de la gravedad de la vulnerabilidad descubierta.

A continuación, se muestran algunos ejemplos:

- Facebook: https://es-es.facebook.com/BugBounty/
- Google: http://www.google.com/about/company/rewardprogram.html
- Microsoft: http://technet.microsoft.com/en-us/security/cc308589
- Netflix: https://help.netflix.com/es-es/node/6657
- Zero Day Initiative: https://www.zerodayinitiative.com/about/

2) Congresos. Existen varios congresos con el propósito de promover el intercambio de conocimientos entre los miembros de la comunidad de seguridad informática. Normalmente, estos congresos se basan en conferencias en las que varios expertos en la materia exponen sus investigaciones, así como en formaciones técnicas o talleres sobre seguridad.

En el ámbito estatal, el congreso más mayoritario se denomina Rooted CON, mientras que en el ámbito europeo podemos destacar el congreso alemán Club de Computación Caos y en el mundial, el congreso americano Black Hat.

3) Blogs. Existen infinidad de blogs de referencia sobre seguridad informática en los que los expertos publican información sobre nuevas vulnerabilidades que se van haciendo públicas, así como estrategias para mitigarlas.

Enlace de interés

Un blog de referencia es *Una al día*, que comenzó en el año 1998: https://unaaldia.hispasec.com.

Esto se debe a que la mayoría de los expertos que empezaron a formarse en el campo de la seguridad informática lo hicieron de manera autodidáctica y compartiendo sus conocimientos vía canales IRC, pero con el auge de la web migraron la forma de compartir sus conocimientos a blogs.

IRC (Internet Relay Chat)

Protocolo de comunicación en tiempo real en el que podéis hablar con un grupo de usuarios al mismo tiempo. Fue la primera red de mensajería de internet, muy popular en los años noventa.

1.1.6. Empresas y usuarios

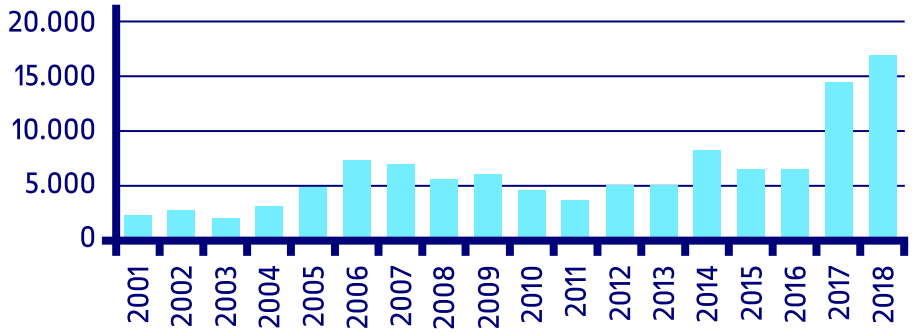
No hay que despreciar las aportaciones que realizan las empresas y los usuarios, sobre todo en la parte de detección de vulnerabilidades, puesto que son las que sufren en primer momento los ataques y las pérdidas derivadas. Del análisis de sus incidentes de seguridad se pueden detectar nuevas vulnerabilidades de software o hardware, que se pueden notificar a sus fabricantes para que las reparen y no afecten a más víctimas.

1.2. Ejemplos de vulnerabilidades

Si recordamos la definición de *vulnerabilidad* como un fallo o debilidad en un sistema que permite que una persona pueda evadir sus restricciones de seguridad, podemos ver que el ámbito en el que puede actuar muy genérico: puede afectar a sistemas informáticos, a aplicaciones o incluso a cómo gestiona la información una empresa.

La figura 2 muestra el número de vulnerabilidades reportadas por año según la web de la National Vulnerability Database (NVD), base de datos de vulnerabilidades del Gobierno de Estados Unidos:

Figura 2. Vulnerabilidades reportadas por año



Fuente: National Vulnerability Database (NVD).

Como se puede ver, existe un fuerte incremento desde el año 2016. Esto nos indica que cada vez se descubren más vulnerabilidades, ya sea porque el software cada vez es más complejo, porque las empresas destinan más recursos a garantizar la seguridad de su software o hardware y por lo tanto detectan más incidencias, o porque cada vez hay más personas interesadas en descubrir estas vulnerabilidades.

Enlace de interés

Usando la web de la National Vulnerability Database (NVD) podemos generar nuestras estadísticas con diferentes criterios marcando la opción «Result Type» con el valor «Statistics». Visitad https://nvd.nist.gov/vuln/search y generad distintas estadísticas.

A continuación se muestran algunos ejemplos de vulnerabilidades:

1) Vulnerabilidad del sistema operativo Windows que aprovechó el software malicioso llamado Conficker para propagarse entre estos sistemas operativos. Este software se aprovechaba de una vulnerabilidad no conocida del protocolo RPC (permite pedir un servicio a un programa de una máquina remota) de los sistemas operativos Windows y tenía la capacidad de propagarse por la red a otros equipos con el mismo sistema operativo, manipular los servicios de la máquina infectada y conectarse a un servidor de internet para recibir instrucciones, como enviar información personal o descargar software malicioso adicional en el ordenador infectado.

Lectura complementaria

Recompensa de Microsoft: **Richard Grigonis** (2009). «Microsoft's $5,000,000 Reward for the Conficker Worm Creators» [artículo en línea]. *TMCnews*. TMCnet. http://technews.tmcnet.com/ipcommunications/topics/ip-communications/articles/50562-microsofts-5000000-reward-the-conficker-worm-creators.htm.

Esta vulnerabilidad tuvo un impacto mundial en 2008 y se catalogó con el identificador único CVE-2008-4250. Finalmente, Microsoft sacó una actualización para solucionar el problema en su boletín de seguridad MS08-067. Tuvo tanto impacto que incluso Microsoft ofreció una recompensa de cinco millones de dólares por la captura de los creadores del software malicioso.

Enlace de interés

Podéis encontrar más información sobre este tema en: https://www.microsoft.com/en-us/wdsi/threats/malware-encyclopedia-description?Name=Win32/Conficker.

2) Disponer de una contraseña débil. No siempre una vulnerabilidad tiene un componente tecnológico. Por ejemplo, podemos disponer de una infraestructura muy segura pero si usamos un usuario y una contraseña predecibles, cualquier persona puede acertarlas y entrar en el sistema con nuestros privilegios.

Se debe intentar no tener el mismo nombre de usuario que la contraseña, así como cambiar las contraseñas por defecto asignadas y usar contraseñas robustas.

Contraseña robusta

Es una contraseña diseñada para que sea difícil de descubrir; normalmente se asigna un mínimo de caracteres que incluya símbolos, mayúsculas, minúsculas y números, por ejemplo «?C2ra/!F+S».

Así como las grandes compañías Google o Facebook, SplashData ha elaborado su particular listado con las contraseñas más utilizadas del año 2018. A continuación, mostramos las diez primeras:

Enlace de interés

Listado completo con las cien contraseñas más utilizadas y más inseguras del mundo: https://www.teampassword.com/blog/worst-passwords-of-2018.

1) 123456

2) password

3) 123456789

4) 12345678

5) 12345

6) 111111

7) 1234567

8) sunshine

9) qwerty

10) iloveyou

2. Clasificación de las vulnerabilidades

Existen diferentes modos de clasificar las vulnerabilidades; aquí mostraremos dos clasificaciones que pueden ser complementarias.

2.1. Desconocidas o conocidas

Primero tenemos que hacer una clasificación entre vulnerabilidades no conocidas, denominadas *de día cero* (0 day), y vulnerabilidades conocidas.

2.1.1. Vulnerabilidades no conocidas (*día cero*)

Una vulnerabilidad no conocida es aquella que es desconocida por cualquiera de los actores que intervienen en la detección y el análisis de vulnerabilidades, es decir, fabricantes de hardware o software, empresas que proporcionan servicios de seguridad, entidades gubernamentales o asociaciones sin ánimo de lucro encargadas de velar por la seguridad informática, CERT, expertos en seguridad informática, empresas y usuarios.

Lectura complementaria

Avast Academy Team (2020, 19 de mayo). «Día cero» [artículo en línea]. https://www.avast.com/es-es/c-zero-day.

Como el fabricante del sistema informático o de la aplicación no tiene conocimiento de la vulnerabilidad, no puede sacar una actualización del producto para repararla, y esto resulta muy peligroso porque la persona que conozca esta vulnerabilidad puede realizar ataques contra una aplicación o sistema informático con el fin de ejecutar código malicioso sin que la víctima lo pueda impedir.

Para poder detectar esta vulnerabilidad, primero se debe ejecutar un ataque con éxito y después, realizando un análisis del incidente de seguridad, se puede llegar a descubrir que se ha usado una vulnerabilidad no conocida. Evidentemente, una vez que la vulnerabilidad pasa a ser conocida, dejará de ser no conocida y se podrá notificar al fabricante del sistema informático o de la aplicación para que realice las acciones necesarias para evitarla, así como informar al resto de los actores que intervienen en la detección y el análisis de vulnerabilidades para intentar mitigar su efecto.

Existe un mercado muy importante de estas vulnerabilidades, tanto el mercado no legal, donde se venden las herramientas para usar estas vulnerabilidades al mejor postor de manera independiente a sus finalidades, como el legal, en el que las empresas pagan una recompensa para tener conocimiento de la vulnerabilidad que afecta a su producto.

Lectura complementaria

INCIBE-CERT (2013). «Mercado legal de vulnerabilidades 0day» [artículo en línea]. Madrid: Instituto Nacional de Ciberseguridad.

2.1.2. Vulnerabilidades conocidas

Las vulnerabilidades conocidas se identifican con un código único denominado **CVE** (Common Vulnerabilities and Exposures). Esta codificación fue creada y es mantenida por MITRE Corporation, organización adscrita al Gobierno de Estados Unidos.

Esta codificación única evita que se publiquen duplicados y permite el intercambio de información entre las diferentes bases de datos de vulnerabilidades y las distintas herramientas que las pueden usar para trabajar, como por ejemplo herramientas de auditoría de seguridad.

Estas vulnerabilidades identificadas con código CVE hacen referencia a vulnerabilidades conocidas a nivel mundial y de ámbito genérico, normalmente sobre software y hardware. Veremos con más detalle este aspecto en el apartado de gestión de las vulnerabilidades de este módulo.

En el ámbito empresarial, podemos detectar otras vulnerabilidades que pueden ser clasificadas como CVE, ya que afectan a la gestión de la información corporativa o a la configuración del sistema informático o de información, y que no garantizan la confidencialidad, disponibilidad o integridad de los datos.

2.2. Tipo de sistema afectado

Podemos clasificar las vulnerabilidades en función del tipo de sistema al que afectan, concretamente sistemas informáticos, aplicaciones o la gestión de la información.

2.2.1. Sistemas informáticos

Cuando el elemento afectado es el sistema informático, la afectación puede incluir los elementos y protocolos de red, el hardware o el sistema operativo.

1) Red. Existen varios tipos de red[2] y elementos de comunicación de información por red, pero todos tienen en común el protocolo de referencia OSI.

[(2)]Una red informática es un grupo interconectado de computadores.

Los sistemas de comunicación utilizan protocolos de comunicación para intercambiar información. Estos protocolos son un lenguaje definido en un estándar presente en todas las etapas necesarias en la comunicación y tienen capacidades de autentificación, corrección de errores, sincronización, etc.

A continuación, se muestran un par de ejemplos de vulnerabilidades que afectan a la red.

a) Modificación de direcciones MAC. La dirección MAC (*media access control*) corresponde a la dirección física de la tarjeta de red del dispositivo electrónico (ordenador, tableta, móvil, televisor, etc.), que es única a escala mundial y permite identificar una tarjeta de red inequívocamente.

Dado que es una dirección única, podríamos pensar que validando solo la información de las direcciones MAC de interés tendríamos blindada nuestra red y no recibiríamos comunicaciones externas. Un ejemplo de esto es la opción que tienen los enrutadores de nuestras casas, que permiten filtrar los dispositivos que se pueden conectar a nuestra a red inalámbrica y autorizan solo las direcciones MAC que indiquemos.

Pues bien, actualmente cambiar la dirección MAC de una tarjeta de red es muy fácil: solo se requiere usar algún software específico, e incluso algunos sistemas operativos permiten su modificación en la configuración de la tarjeta de red.

Evidentemente, una red que solo implemente seguridad de autentificación por las direcciones MAC es vulnerable.

b) Vulnerabilidades DNS. El DNS (*domain name system*) permite la traducción de nombres de dominio, por ejemplo www.uoc.edu, a una dirección IP. De este modo se facilita el uso de las direcciones por parte de los usuarios, puesto que los dominios son más fáciles de recordar que las direcciones IP numéricas y además permiten flexibilidad a la hora de mantener las direcciones IP asignadas a un dominio.

Si algún atacante consigue modificar los servidores DNS globales o de nuestros equipos (enrutadores u ordenadores) aprovechando una vulnerabilidad, se pueden provocar varios tipos de ataques.

Imaginemos que un DNS global modifica sus registros y traduce la dirección www.google.es por la IP del servidor de una compañía dedicada a la venta en línea. En este caso, la web de venta en línea puede dejar de funcionar por la gran cantidad de peticiones que puede recibir, puesto que cualquier persona del mundo que acceda al buscador Google estará haciendo una petición a la web de venta en línea. Se estaría produciendo un ataque de denegación de servicio o DOS (*denial of service*).

Otro posible ataque sería modificar los DNS de nuestro enrutador de casa o del ordenador que usamos para que tradujera incorrectamente la dirección de nuestro banco en línea con el fin de que al entrar en él accedamos a un servidor falso con la misma apariencia que nuestro banco, pero con la función de guardar nuestras credenciales. Esto se denomina *pharming*.

2) Hardware y *firmware*. Dentro de esta clasificación tenemos las vulnerabilidades que afectan al hardware y a su software de gestión. Este hardware puede ser muy variado en función de la organización e ir desde los elementos de los ordenadores de los trabajadores, a cajeros automáticos (ATM), elementos de red como conmutadores (*switchs*), componentes de los teléfonos móviles, etc.

Lectura complementaria

Vladislav Biryukov (2015, 2 de abril). «5 amenazas que afectan el hardware» [artículo en línea]. *Karpersy Daily*. https://latam.kaspersky.com/blog/5-amenazas-que-afectan-el-hardware/5218/.

En el apartado de actores involucrados en la gestión de las vulnerabilidades se comenta la vulnerabilidad llamada Spectre, pero hay muchas más.

3) Sistemas operativos. Los sistemas operativos son un conjunto de programas que gestionan los recursos de un ordenador y permiten la interacción humano-ordenador.

Los sistemas operativos más conocidos por los usuarios son Windows, Linux, Android, iOS y OS X.

Las principales vulnerabilidades que afectan a los sistemas operativos tienen el objetivo de obtener acceso remoto sin consentimiento o realizar una escalada de privilegios, con la cual un usuario del sistema aumenta sus privilegios y puede acceder a más información de a la que debería de tener acceso.

En el apartado de ejemplos de vulnerabilidades de este módulo hemos visto la del sistema operativo Windows, concretamente de su servicio RPC, que aprovechó el software malicioso llamado Conficker para propagarse entre estos sistemas operativos.

Los sistemas operativos de dispositivos móviles también tienen vulnerabilidades, como la CVE·2018-9489, que permitía que cualquier aplicación instalada en el dispositivo pudiera geolocalizar el terminal sin permiso del usuario.

Lectura complementaria

Nightwatchcyber (2018, 29 de agosto). «Sensitive Data Exposure via WiFi Broadcasts in Android OS [CVE-2018-9489]» [artículo en línea]. Nigthwatch Cibersecurity. https://wwws.nightwatchcybersecurity.com/2018/08/29/sensitive-data-exposure-via-wifi-broadcasts-in-android-os-cve-2018-9489/.

2.2.2. Aplicaciones

Tradicionalmente, siempre se han destacado las vulnerabilidades de las aplicaciones web, pero en realidad pueden encontrarse en cualquier tipo de aplicación, tanto de escritorio como de dispositivos móviles o cualquier otro:

1) Aplicaciones de escritorio. Por *aplicaciones de escritorio* se entiende aplicaciones instaladas en el sistema operativo, como por ejemplo un reproductor de vídeo instalado en el sistema operativo Windows.

Existe un riesgo potencial en la instalación de una aplicación en el sistema operativo, puesto que en muchas ocasiones requiere permisos de administrador. El problema radica en la fiabilidad que tiene la aplicación, es decir, no es lo mismo instalar una aplicación comprada legítimamente que una descargada por internet, que suele venir acompaña de otro fichero ejecutable que nos garantiza que activará la aplicación instalada como si fuera original.

En caso de instalar software desconocido, asumimos muchos riesgos, como la instalación de software malicioso, que será una vulnerabilidad que explotarán posteriormente para formar parte de una red zombi, secuestro de información o robo de información privada.

Lectura complementaria

Red zombi: **Dennis Fisher** (2013, 23 de abril). «Qué es un botnet» [artículo en línea]. *Karpersy Daily*. https://www.kaspersky.es/blog/que-es-un-botnet/755/.

Las aplicaciones legítimas también pueden tener vulnerabilidades como, por ejemplo, una aplicación de una organización en la que un usuario, haciendo una acción determinada, puede ver información privada a la que no debería tener acceso; en este caso la aplicación no proporciona las restricciones de seguridad necesarias para garantizar la confidencialidad, integridad, disponibilidad, control de acceso y consistencia del sistema o de sus datos.

2) Aplicaciones para dispositivos móviles. El uso masivo de los teléfonos móviles ha hecho que la información sensible de las organizaciones no solo esté almacenada en los ordenadores y servidores de la compañía. Igual que las aplicaciones de escritorio, las aplicaciones que instalemos en nuestros dispositivos móviles tienen que ser de confianza para evitar riesgos.

Las aplicaciones legítimas pueden contener vulnerabilidades derivadas de su código. Este es el caso de una vulnerabilidad de la aplicación de mensajería más importante a nivel mundial, WhatsApp, que permitía a los ciberdelincuentes espiar a los usuarios de esta aplicación.

Lectura complementaria

0 day WhatsApp: **Alex-Perekalin** (2019, 14 de mayo). «Una llamada en WhatsApp basta para que te espíen» [artículo en línea]. *Karpersy Daily*. https://www.kaspersky.es/blog/whatsapp-call-zeroday/18429/.

Las aplicaciones legítimas pueden contener vulnerabilidades derivadas de código compartido de otras aplicaciones. Por ejemplo, la vulnerabilidad CVE-2015-8540 afectaba a una librería de programación llamada *libpng* y utilizada para trabajar con imágenes PNG, y por lo tanto todas las aplicaciones de Android que hacían referencia a esta librería eran vulnerables, aunque su código fuera legítimo.

Enlace de interés

Referencia Google: https://support.google.com/faqs/answer/ 7011127?hl=es-419.

3) Aplicaciones web. El uso masivo de internet provoca que la mayoría de los ataques vayan dirigidos sobre aplicaciones web, como venta en línea o webs privadas protegidas por usuario y contraseña, con la intención de descubrir alguna vulnerabilidad del propio funcionamiento del software para sacar un provecho.

Para las aplicaciones web, existe una fundación formada por empresas, organizaciones educativas y particulares de todo el mundo dedicada a detectar vulnerabilidades y crear artículos, metodologías, documentación e incluso herramientas de detección que son utilizadas en las pruebas de intrusión. Esta fundación se llama OWASP, sigla de Open Web Application Security Project.

OWASP genera un documento llamado OWASP Top 10, que recoge las diez vulnerabilidades más importantes detectadas en aplicaciones web cada tres años, con el fin de concienciar sobre la seguridad en las aplicaciones y los riesgos que asumen las organizaciones.

El último informe publicado por OWASP corresponde al Top Ten 2017 y a continuación detallamos brevemente las vulnerabilidades más comunes que suelen ser explotadas por un atacante:

Enlace de interés

OWASP Top 10 2017: https://owasp.org/www-project-top-ten/OWASP_Top_Ten_2017/.

- **A1:2017-Injection**. Ataques de inyección, como por ejemplo *sql injection*, inyección de comandos o *LDAP injection*, entre otros. Un atacante podría acceder a información o ejecutar órdenes sobre un sistema sin autorización.

- **A2:2017-Broken Authentication**. Ataques producidos en entornos en los que hay una mala gestión de la autenticación o de la gestión de las sesiones. Un atacante podría suplantar la identidad de un usuario o acceder a datos sin autorización.

- **A3:2017-Sensitive Data Exposure**. Vulnerabilidad que permite que aplicaciones web o su API (*application programming interface*) no protejan adecuadamente información sensible y, por lo tanto, se puedan producir posibles fugas de información.

- **A4:2017-XML External Entities (XXE)**. Las referencias de entidades externas dentro de los documentos XML se pueden utilizar para revelar ficheros internos mediante el gestor de URI de ficheros, compartición de ficheros internos, exploración de puertos internos, ejecución de código remota y ataques de denegación de servicio.

- **A5:2017-Broken Access Control**. Vulnerabilidad que permite que usuarios no autenticados o sin permisos accedan a zonas de la aplicación que no están correctamente protegidas, por ejemplo que no validan que el usuario tiene sesión iniciada.

- **A6:2017-Security Misconfiguration**. Errores en la configuración de la seguridad de todos los elementos que forman parte de una aplicación web, como son el propio servidor web, el servidor de aplicaciones, servidor de bases de datos, etc. Asimismo, también se considera fallo la falta de configuración de cualquier elemento.

- **A7:2017-Cross-Site Scripting (XSS)**. Ataques que se producen en el lado del cliente cuando no se producen las validaciones requeridas en los datos de entrada o salida en las aplicaciones. Un atacante puede aprovechar esta vulnerabilidad de la aplicación para ejecutar *scripts* en el navegador de la víctima o para efectuar acciones no autorizadas.

- **A8:2017-Insecure Deserialization**. Para entender esta vulnerabilidad, hemos de entender los conceptos de *serialization* y *deserialization*. El primero hace referencia a cuando un programa informático transforma un objeto de su código en un formato que puede enviar por la red para que otro programa lo reciba y vuelva a generar este objeto mediante un proceso de *deserialization*. Esta vulnerabilidad se produce cuando un programa recibe un objeto serializado, pero al hacer el proceso de *deserialization*, el objeto generado no es el esperado y, a menudo, conduce a la ejecución remota de código. Incluso si los efectos de *deserialization* no generan ejecución remota de código, se pueden utilizar para realizar otros tipos de ataques, como de inyección o de escalada de privilegios.

Lectura complementaria

Acunetix (2017, 7 de diciembre). «What is Insecure Deserialization?» [artículo en línea]. https://www.acunetix.com/blog/articles/ what-is-insecure-deserialization/.

- **A9:2017-Using Components with Known Vulnerabilities**. Vulnerabilidad que se encuentra en los componentes utilizados por la aplicación web, como, por ejemplo, librerías externas o *frameworks* de desarrollo que tienen vulnerabilidades conocidas. Es decir, aunque el código de nuestras aplicaciones sea seguro, si usa código externo o librerías externas, tenemos que verificar que estos sean las últimas versiones y que no tengan vulnerabilidades que puedan afectar a nuestro programa.

- **A10:2017-Insufficient Logging&Monitoring**. Una monitorización y generación de *logs* insuficiente, junto con una integración ineficaz o inexistente con un sistema de respuesta de incidentes, permiten a los atacante que han conseguido acceso al sistema continuar atacando el sistemas accesible, mantener la persistencia, pivotar hacia más sistemas para manipular, extraer o destruir datos. Hay que tener presente que la mayoría de los estudios sobre incidentes graves demuestran que el tiempo para detectar una infracción es superior a doscientos días y que normalmente son detectados por entidades externas en lugar de los procesos de monitorización y controles internos de la víctima.

La mejor manera de entender cómo funcionan las vulnerabilidades de aplicaciones web es experimentarlas. Para ello, existe una aplicación web diseñada con varias vulnerabilidades, en especial las relativas a OWASP Top Ten, con el nombre WebGoat, que se puede descargar y que integra una guía para probar las vulnerabilidades, indicándonos si hemos tenido éxito en nuestro ataque.

2.2.3. Gestión de la información

No solo existen vulnerabilidades en productos tecnológicos, puesto que podemos disponer de mucha seguridad, pero si no tenemos procedimientos seguros establecidos para la gestión de la información y personal capacitado, no estamos garantizando la seguridad.

El factor humano en la gestión de la información puede generar vulnerabilidades y esto lo conocen los ciberdelincuentes, por lo que generan nuevas estrategias para vulnerar la seguridad de las organizaciones usando como vector de ataque el engaño de los propios trabajadores de la organización. En el próximo módulo veremos con más detalle aspectos que afectan al factor humano, como la ingeniería social.

Un ejemplo de vulnerabilidad en la gestión de la información es tener las credenciales de acceso al ordenador apuntadas en un papel encima de la mesa o pegado en la pantalla. Aunque no lo parezca, esta práctica es muy habitual.

Una técnica de engaño muy habitual en este tipo de vulnerabilidad es la suplantación de identidad; por ejemplo, el ciberdelincuente se hace pasar por un alto cargo de una empresa o por otra empresa con el fin de engañar a algún trabajador y conseguir que le hagan alguna transferencia económica.

Lectura complementaria

Josep Albors (2019, 2 de octubre). «Fraude del CEO: así consiguen estafar millones a empresas de todo el mundo» Blog Protegerse [artículo en línea] https://bit.ly/36Su3SO.

3. Gestión de las vulnerabilidades

Los diferentes actores que intervienen en la detección y el análisis de vulnerabilidades tienen un procedimiento estandarizado para gestionar las detecciones de nuevas vulnerabilidades, de modo que se evita la duplicación y se comparte la información con varios organismos para validarla e incluso publicar una solución al problema, sea para repararlo o para minimizar su impacto.

Este procedimiento corresponde a la obtención del código CVE, que se puede resumir en las siguientes etapas:

1) Se descubre una vulnerabilidad.

2) Se busca información de si esta vulnerabilidad ya ha sido reportada. Para hacerlo, se busca en las bases de datos CVE y se puede contactar con el proveedor del software o hardware para ver si tiene conocimiento de la vulnerabilidad.

3) Se solicita un identificador CVE. Esta primera etapa se denomina *candidatura* e intervienen en ella las empresas y organizaciones autorizadas por MITRE Corporation para valorar los parámetros y riesgos de las vulnerabilidades nuevas. Estas empresas se llaman CNA (Candidate Numbering Authority), que significa Autoridad de Numeración CVE.

4) La vulnerabilidad se publica en estado «candidatura» y si finalmente se acepta como vulnerabilidad, se cambia el estado a «entrada».

Cada vulnerabilidad de la lista de CVE contiene la siguiente información:

- **Número de identificación CVE** (figura 3).

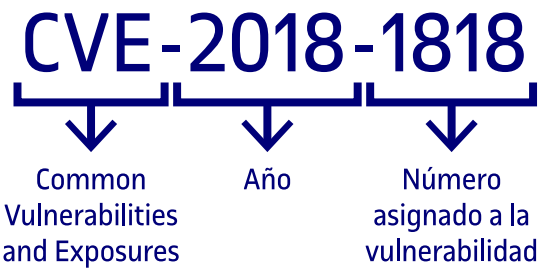
- **Estado («candidatura» o «entrada»)**. El estado «candidatura» (*candidate*) indica que la vulnerabilidad ha sido reportada y se está verificando su existencia y su impacto. Mientras que el estado «entrada» (*entry*) indica que la vulnerabilidad ha pasado a formar parte de la lista de CVE.

- **Descripción de la vulnerabilidad**. La parte de «Descripción» de las entradas de CVE normalmente está escrita por las autoridades de numeración de CVE (CNA), el equipo de CVE o las personas que solicitan una ID de CVE. Las descripciones tienen que ser únicas y deben proporcionar los detalles relevantes para ayudar a los usuarios a encontrar la entrada CVE para una vulnerabilidad específica o distinguir entre vulnerabilidades de aspecto similar. Lo ideal es que las descripciones incluyan detalles como el nombre del proveedor y el producto afectado, un resumen de las versiones afectadas, el tipo de vulnerabilidad, el impacto, el acceso que requiere un

atacante para explotar la vulnerabilidad (vector de ataque) y los componentes o entradas importantes del código que están involucrados.

- **Referencias**. Estas referencias pueden ser informes, boletines de seguridad, enlaces externos o cualquier otro contenido relevante para la vulnerabilidad.

Figura 3. Número de identificación CVE

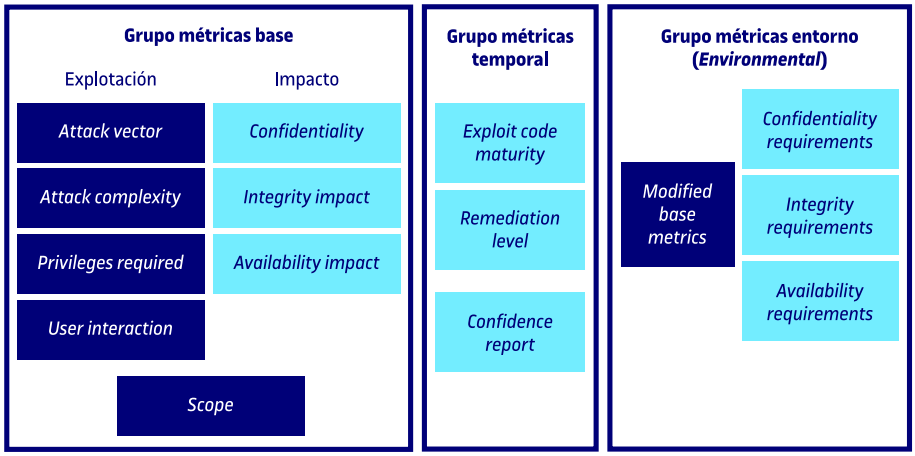


Fuente: elaboración propia.

Las bases de datos de vulnerabilidades muestran información sobre la capacidad de impacto que la vulnerabilidad puede tener, que se establece entre los parámetros bajo, medio, alto o crítico. Para calcular este valor, se utiliza CVSS (Common Vulnerability Scoring System), que es una métrica de evaluación del impacto o gravedad de la vulnerabilidad.

Este valor CVSS se basa en unos cálculos matemáticos sobre tres grupos principales de métricas evaluadas, que son base, temporal y entorno (figura 4).

Figura 4. Grupos principales de métricas evaluadas



Fuente: Incibe-Cert métricas CVSS 3.0.

De los cálculos matemáticos de estas métricas resulta un valor comprendido entre el 0 y el 10, y se establece el nivel de impacto de la vulnerabilidad de la manera que se muestra en la tabla 1.

Tabla 1. Correspondencia entre valor CVSS e impacto de la vulnerabilidad

Valor CVSS	Nivel de impacto
0	Nulo
0,1-3,9	Bajo
4,0-6,9	Medio
7,0-8,9	Alto
9,0-10	Crítico

Fuente: métricas de evaluación de vulnerabilidades CVSS.

Este sistema de cálculo permite disponer de un estándar en las organizaciones para establecer criterios consistentes a la hora de gestionar las vulnerabilidades, analizando la importancia de las vulnerabilidades de la organización para priorizar las medidas de seguridad que se deben aplicar.

El CVSS lo desarrolló inicialmente un organismo norteamericano: el NIAC (National Infrastructure Advisory Council), pero actualmente es mantenido y desarrollado por la organización FIRST, organización mundial líder en respuesta a incidentes, que ofrece recursos en línea como la especificación o una calculadora en línea para facilitar los cálculos de las métricas.

Recursos en línea FIRST

Documento de especificación: https://www.first.org/cvss/specification-document.

Calculadora en línea: https://www.first.org/cvss/calculator/3.0.

En cuanto a la gestión de vulnerabilidades dentro de una empresa, existen estándares de gestión de la seguridad que nos ayudan a identificarlas para poder priorizarlas y corregirlas en función de las necesidades de la empresa, puesto que hay que recordar que no todas las vulnerabilidades tienen el mismo impacto dentro de la organización.

Estas políticas de gestión y revisión continua nos proporcionan una forma sistemática de identificar, analizar, categorizar y corregir vulnerabilidades dentro de la organización.

A continuación se enumeran algunas guías de referencia:

- Normas ISO 27000. La ISO 27002 hace referencia al código de buenas prácticas, mientras que la ISO 27001 se refiere a los requisitos que debe tener un sistema de gestión de seguridad de la información.
- Normas relativas a la continuidad del negocio o de los servicios de las tecnologías de la información y la comunicación (TIC). Los planes de continuidad de negocio persiguen los objetivos de mantener el nivel de servicio en los límites mínimos que ha definido la compañía para considerar que la actividad no está interrumpida y recuperar el servicio (situación inicial) en caso de algún fallo. Dentro de esta categoría tenemos las normas BS 25999, sobre los requisitos de la gestión de la continuidad del negocio basados en el código de buenas prácticas, o la BS 25777, sobre la gestión de la continuidad de las TIC.

- COBIT (*control objectives for information and related technology*) e ITIL (*information technology infrastructure library*). Estas normas nos ayudan a disponer de buenas prácticas para planificar los servicios de las TIC de la compañía, proveerla de estos servicios y darle apoyo.

En todos los casos implica trabajar sobre los siguientes puntos de la organización:

- Conocimiento del negocio: es necesario conocer los procesos de negocio e identificar los más críticos, lo que permitirá priorizar las acciones.
- Análisis de riesgos: analizar los riesgos a los que está expuesto el negocio y el impacto que generaría la detección de una vulnerabilidad sobre estos.
- Establecer controles técnicos y organizativos para gestionar tanto la revisión continua del sistema como la gestión que se efectúa después de una identificación de una vulnerabilidad.

4. Análisis de las vulnerabilidades

El objetivo del análisis de vulnerabilidades consiste en el descubrimiento, la identificación y la clasificación de las vulnerabilidades presentes en los sistemas informáticos o de información de nuestra organización.

4.1. Metodología

Podríamos diferenciar dos tipos de metodologías de identificación y análisis de vulnerabilidades:

- Metodología preventiva
- Metodología reactiva

4.1.1. Metodología preventiva

Dentro del proceso de revisión continua de la seguridad interna de la empresa se encuentran las pruebas de intrusión y las revisiones de la gestión de la información corporativa o del Sistema Gestor de la Seguridad de la Información (SGSI).

1) Pruebas de intrusión. Estas pruebas tratan de escanear los sistemas corporativos (red, servidores o aplicaciones) para encontrar vulnerabilidades. Este escaneo suele ser efectuado con alguna herramienta automatizada y, en función de sus resultados, se puede ampliar con análisis manuales por parte de los auditores.

El primer punto que se debe establecer en las pruebas de intrusiones es el alcance de estas, es decir, qué parte del sistema se analiza y de qué información previa se dispone. En función de esta información, las podemos catalogar como:

- **Caja Blanca (*White Box*)**. El personal que realiza las pruebas de intrusión tiene conocimiento de toda la información esencial de la empresa, como usuarios, contraseñas, estructura de la red, etc.

- **Caja Negra (*black Box*)**. El personal que realiza las pruebas de intrusión no tiene ninguna información sobre la empresa, y es similar a un ataque externo que podría realizar una persona de fuera de la empresa.

- **Caja Gris (*Gray Box*)**. Este tipo de prueba de intrusión es una combinación de las anteriores, es decir, se dispone de información de la empresa, pero esta es muy baja. Por ejemplo, se dispone de un usuario restringido de la

Enlace de interés

Existen iniciativas para estandarizar los procedimientos de proceso de intrusión, como el Penetration Testing Execution Standard (PTES): http://www.pentest-standard.org/.

red para evaluar si es posible escalar privilegios para acceder a información a la que no se debería tener acceso.

Las fases establecidas en las pruebas de intrusiones son las siguientes:

- **Reconocimiento**. Esta fase se encarga de recopilar toda la información posible sobre el sistema que se va a evaluar, como por ejemplo la estructura de la red.

- **Búsqueda de vulnerabilidades**. A partir de la información de la fase de reconocimiento, se ejecutan herramientas de escaneo para intentar localizar vulnerabilidades o vectores de ataques.

- **Explotación de las vulnerabilidades**. Dentro de esta fase se ejecutan *exploits* para aprovechar una vulnerabilidad y obtener acceso a los sistemas analizados.

- **Postexplotación**. Una vez que tenemos acceso a alguna parte del sistema, se intentará realizar una escalada de privilegios para aumentar los privilegios de acceso a los sistemas o vulnerar otros sistemas con más importancia para la organización.

- **Informe**. Se tiene que redactar un documento con el resultado de todas las pruebas, como herramientas utilizadas, técnicas, vulnerabilidades descubiertas y recomendaciones para evitarlas.

Exploit

Un *exploit* no es más que un trozo de código (*script*), porción de software o conjunto de pedidos que toman ventaja de un error o vulnerabilidad para causar un comportamiento inesperado de un software o hardware.

2) Revisiones de la gestión de la información. Es muy importante revisar cómo se gestiona la información dentro de la empresa, revisando políticas, normas y procedimientos organizativos, así como la definición de las funciones de seguridad, la elaboración del plan de continuidad de negocio o la formación y concienciación.

4.1.2. Metodología reactiva

Esta modalidad de análisis está causada por la detección de un incidente de seguridad, que puede ser reportada tanto por un trabajador como por un sistema de alertas de monitorización de nuestros sistemas.

Lectura complementaria

INTECO (2013). *Identificación y reporte de incidentes de seguridad para operadores estratégicos. Guía básica de protección de infraestructuras críticas*. Madrid: Instituto Nacional de Tecnologías de la Comunicación (INTECO).

Las fases de los incidentes de seguridad son las siguientes:

- **Identificación**. El objetivo de esta fase es determinar si ha habido una violación de nuestras políticas de seguridad, así como determinar su alcance y los sistemas involucrados. Se tiene que verificar la vulnerabilidad empleada para realizar el ataque.

- **Contención y mitigación del impacto del ataque**. Una vez identificado el ataque, se deben aplicar las medidas necesarias para que los efectos cau-

sados por el ataque no aumenten y, en caso de que sea posible, mitigarlo. Por ejemplo, en caso de detectar una cuenta vulnerada, esta puede ser bloqueada por motivos de seguridad.

- **Fuga de información y adquisición de evidencias**. Se tiene que evaluar la afectación que ha podido tener el ataque mientras ha estado activo y qué información puede haber sido afectada. Asimismo, se han de preservar las evidencias digitales del incidente por si deriva en alguna acción judicial.

- **Recuperación**. En esta fase, el sistema tiene que volver al punto de partida anterior al momento en el que recibió el ataque, evidentemente corrigiendo la vulnerabilidad descubierta para evitar su reproducción.

- **Documentación y acciones correctivas**. Se tiene que documentar el incidente, verificar si hay alguna implicación legal derivada y realizar las acciones correctivas necesarias para evitar su reproducción, como por ejemplo aplicar las correcciones descritas para la vulnerabilidad detectada.

4.1.3. Metodologías de análisis de vulnerabilidades de aplicaciones o código malicioso

Principalmente, existen dos metodologías para analizar vulnerabilidades de aplicaciones o de código malicioso, y que son empleadas por software especializado como los antivirus.

1) Análisis estático

El análisis estático se basa en el análisis del código de las aplicaciones o sus procesos de ejecución con el objeto de localizar algún patrón conocido que identifique una acción maliciosa.

Estos patrones que se han de buscar se llaman *firmas* y tienen que ser conocidos antes de buscarlos. Por tanto, no podremos garantizar la detección de las nuevas vulnerabilidades o de códigos maliciosos que han realizado mecanismos de evasión para aprovechar vulnerabilidades conocidas pero que generen firmas diferentes. Una de las características de este análisis es que no supone la ejecución de la aplicación o el código; de este modo, se puede hacer un primer análisis antes de su ejecución para evitar posibles infecciones.

Los investigadores en seguridad utilizan la técnica llamada *ingeniería inversa* para evaluar los códigos y detectar si son maliciosos o incluso si usan vulnerabilidades, tanto conocidas como nuevas. Esta técnica consiste en extraer todos

los componentes del software para comprender su funcionamiento y traducir el código de la aplicación a una estructura comprensible por los expertos en esta técnica.

La ingeniería inversa es una técnica muy difícil que requiere un completo conocimiento y el uso de herramientas especializadas, como Ghidra, creada por la Agencia de Seguridad Nacional (NSA) de Estados Unidos.

Enlace de interés

Herramienta Ghidra para ingeniería inversa:
https://ghidra-sre.org.

2) Análisis dinámico

El análisis dinámico se basa en el análisis del comportamiento de la ejecución del código de la aplicación o el código malicioso.

Una vez que se ejecuta la aplicación maliciosa, se analizan dos parámetros:

- **Acciones realizadas**. Se intenta localizar acciones conocidas por códigos maliciosos o acciones sospechosas que no tendría que realizar la aplicación. Por ejemplo, generar una carpeta en un lugar, generar un fichero ejecutable e intentar inyectarlo en un proceso de memoria que actualmente ocupa un proceso legítimo del sistema.

- **Firmas de los procesos o ficheros generados en ejecución**. Se intenta realizar un análisis estático de los procesos o ficheros generados de manera dinámica durante la ejecución, para buscar algún patrón conocido que identifique una acción maliciosa.

Una de las características de este tipo de análisis es que implica la ejecución de la aplicación o del código; por lo tanto, es recomendable realizarlo en un entorno externo y controlado para no afectar a entornos de producción. Una alternativa a disponer de hardware externo destinado a ello suele ser utilizar un entorno *sandbox*, que consiste en la ejecución del código en un sistema virtual aislado para realizar el análisis y, en función del resultado de la detección, permitir la ejecución en el hardware original. La ventaja de utilizar un entorno *sandbox* es que se puede comparar el estado de la máquina virtual antes y después de la ejecución del código para ver qué modificaciones ha realizado en el sistema y determinar si estas son legítimas o no, así como realizar un análisis del uso de la red para ver dónde se conecta, qué tipo de comunicación realiza o incluso si descarga algún archivo.

Actualmente hay varios antivirus que disponen de entornos *sandbox* integrados para analizar programas que se ejecutan de manera transparente al usuario, aunque requieren un tiempo de procesamiento que puede hacer notar al usuario que el ordenador va más lento al abrir ciertas aplicaciones.

Para realizar un análisis dinámico de las vulnerabilidades en las aplicaciones web suele ser habitual efectuar un test de intrusión específico usando la guía de la fundación OWASP, Open Web Application Security Project.

4.2. Mecanismos de evasión

Los creadores de software malicioso conocen los sistemas de detección y análisis que se utilizan, por lo que intentan utilizar algunos de los siguientes mecanismos de evasión para no ser detectados:

- **Empaquetado y ofuscación**. Para evitar estudios manuales de ingeniería inversa del código, se usan estas técnicas, que consisten en alterar el orden de ejecución, camuflar estructuras o comprimir partes del código.

- **Detección de ejecución en entornos virtuales**. Permite al código malicioso cambiar de comportamiento si detecta que se está analizando en un entorno virtual como una *sandbox*. De este modo, si detecta que lo están analizando, no realiza ninguna actividad que pueda concluir que se trata de un código malicioso.

- ***Anti-debugging***. Esta técnica consiste en varios métodos para evitar que se pueda realizar un *debug* de la aplicación, es decir, monitorizar las acciones que está realizando en el sistema operativo el software malicioso.

- **Criptografía**. Usar comunicaciones cifradas o incluso cifrar el código de la aplicación para que no se detecte su firma, y descifrarlo solo en tiempo de ejecución.

4.3. Herramientas

A continuación se enumeran una serie de herramientas que se pueden usar para la detección y el análisis de vulnerabilidades, clasificadas por funcionalidad:

- **Herramientas de escaneo de puertos**. En informática, un puerto es una interfaz lógica que permite la transmisión de datos entre diferentes ordenadores, es decir, por donde enviamos y recibiremos información por la red. Normalmente son utilizados por las aplicaciones o los servicios del ordenador. Estas herramientas sirven para buscar los ordenadores de la red accesibles y qué aplicaciones o servicios tienen activados para atender las comunicaciones de la red. La herramienta más famosa es Nmap.

- **Herramientas de análisis de tráfico de red**. Estas herramientas permiten capturar y analizar el tráfico de datos de nuestra red. De esta manera, podemos detectar conexiones sospechosas o patrones de ataque, como por

ejemplo si alguien está efectuando un escaneo de puertos. La herramienta más famosa es Wireshark.

- **Herramientas de escaneo de vulnerabilidades**. Estas herramientas realizan un escaneo de las vulnerabilidades conocidas (CVE) y de las vulnerabilidades más habituales de las aplicaciones web (inyecciones de código, etc.). Normalmente son herramientas utilizadas en las pruebas de intrusión que efectúan las organizaciones, puesto que disponen de capacidad para explotar las vulnerabilidades detectadas y generar un informe con el resultado obtenido. Las herramientas más famosas son Metasploit, Nessus y Owasp Zep para pruebas de intrusión en aplicaciones web.

- **Herramientas para validar la seguridad de la red inalámbrica (WiFi)**. Muchas organizaciones disponen de conexiones de redes inalámbricas y deben asegurar que estas tengan el nivel de seguridad óptimo. La herramienta más famosa es Aircrack-ng.

- **Herramientas para validar la fortaleza de las contraseñas de los usuarios del sistema**. Se tiene que validar que los usuarios o servicios de acceso de la organización disponen de una contraseña robusta que no sea predecible; para ello, disponemos de herramientas para intentar buscar contraseñas por defecto de los servicios o realizar ataques de diccionario o de fuerza bruta con el fin de intentar extraer cuentas o contraseñas de los usuarios. Destacamos las siguientes herramientas:
  - John the Ripper es una de las herramientas más famosas para realizar ataques de fuerza bruta para descifrar contraseñas encriptadas.
  - THC Hydra y Medusa resultan de gran utilidad para buscar contraseñas y usuarios de servicios en red.

- **Herramientas de descompilación e ingeniería inversa**. Estas herramientas son utilizadas para evaluar los códigos y detectar si son maliciosos o incluso si usan vulnerabilidades, tanto conocidas como nuevas, mediante la traducción del código de la aplicación a una estructura comprensible por los expertos en esta técnica. Destacamos las siguientes herramientas:
  - Ghidra
  - IDA

- **Herramientas de análisis forense**. Estas herramientas sirven para extraer información relevante de los dispositivos utilizando una metodología válida para buscar evidencias digitales que puedan ser empleadas como prueba judicial. La herramienta gratuita más famosa es Sleuthkit, que puede ser utilizada de modo gráfico mediante la herramienta Autopsy. Asimismo, para analizar la memoria RAM de los dispositivos, existe la herramienta Volatility.

Resumen

En este módulo hemos definido el concepto de incidente de seguridad y de vulnerabilidad de un sistema de información, al tiempo que hemos visto que hay diferentes actores que intervienen en la detección y el análisis de las vulnerabilidades, actores que tienen diferentes tareas y funciones.

También hemos aprendido a consultar estadísticas de las vulnerabilidades publicadas, que han ido creciendo en los últimos años, y dos sistemas de clasificación de las vulnerabilidades en función de si son conocidas o desconocidas y dependiendo del tipo de sistema afectado; también hemos visto diferentes tipos de ejemplos de vulnerabilidades para cada clasificación.

Posteriormente, hemos estudiado cómo se gestionan las vulnerabilidades y el procedimiento de obtención del código CVE, así como las metodologías utilizadas en el análisis de las vulnerabilidades y cómo los creadores de software malicioso intentan evadirlas.

Para finalizar, se han enumerado herramientas utilizadas en la detección y el análisis de vulnerabilidades, clasificadas por su funcionalidad.

Glosario

ataque informático *m* Acto intencionado y deliberado que intenta evadir las restricciones de seguridad de un sistema informático para sacar un provecho o realizar unos daños.

CERT *m* Véase Computer Emergency Response Team.

Common Vulnerabilities and Exposures *m* Sistema de identificación de vulnerabilidades más conocido y que se usa a nivel mundial.

Common Vulnerability Scoring System *m* Métrica de evaluación del impacto o la gravedad de la vulnerabilidad.

Computer Emergency Response Team *m* Denominación de los CSIRT de Estados Unidos.

Computer Security Incident Response Team *m* Centro de respuesta a incidentes de seguridad en tecnologías de la información formado por expertos en la materia.

contraseña débil *f* Contraseña predecible que cualquier persona puede acertar y con la que puede entrar al sistema con nuestros privilegios.

CVE *m* Véase Common Vulnerabilities and Exposures.

CVSS *m* Véase Common Vulnerability Scoring System.

denegación de servicios (DoS) *m* Ataque con el objetivo de inhabilitar el uso de un sistema, aplicación o hardware para bloquear el servicio para el que está destinado.

DoS *m* Véase denegación de servicios.

emphasis *m* Sistema aislado o máquina virtual para ejecutar un código o aplicación que permita analizarlo y determinar su comportaminto

Equipo de Respuesta ante Incidencias de Seguridad Informática *m* Centro de respuesta a incidentes de seguridad en tecnologías de la información donde trabajan expertos en la materia.
en Computer Security Incident Response Team

escalada de privilegios *f* Acto de explotación de una vulnerabilidad dentro de un sistema operativo o aplicación para conseguir acceso a recursos del sistema más elevados que el usuario que efectúa el ataque.

explotador *m* Código (*script*), porción de software o conjunto de pedidos que toman ventaja de un error o vulnerabilidad para causar un comportamiento inesperado de un software o hardware.

microprogramario *m* Software que establece la lógica de más bajo nivel de un hardware para controlar sus circuitos electrónicos.

política de seguridad *f* Restricciones de seguridad de un sistema informático para garantizar la confidencialidad, la integridad, la disponibilidad, el control de acceso y la consistencia del sistema o de sus datos.

SGSI *m* Véase Sistema gestor de la seguridad de la información.

Sistema gestor de la seguridad de la información *m* Sistema de gestión que comprende la política, la estructura organizativa, los procedimientos, los procesos y los recursos necesarios para implantar la gestión de la seguridad de la información.

vector de ataque *m* Acceso que requiere un atacante para explotar la vulnerabilidad.

vulnerabilidad *f* Fallo o debilidad en un sistema que permite que una persona pueda evadir sus restricciones de seguridad.

Bibliografía

Acunetix (2017, 7 de diciembre). «What is Insecure Deserialization?» [artículo en línea]. <https://www.acunetix.com/blog/articles/what-is-insecure-deserialization/>.

Avast Academy Team (2010, 19 de mayo). «Día cero» [artículo en línea]. <https://www.avast.com/es-es/c-zero-day>.

Biryukov, Vladislav (2015, 2 de abril). «5 amenazas que afectan el hardware» [artículo en línea]. *Karpersy Daily*. <https://latam.kaspersky.com/blog/5-amenazas-que-afectan-el-hardware/5218/>.

Caballero Velasco, María Ángeles; Cilleros Serrano, Diego (2018). *El libro del hacker*. Madrid: Anaya.

CNN-CERT (2020). *Guías CCN-STIC de Seguridad* [guías en línea]. Madrid: Centro Criptológico Nacional. <https://www.ccn-cert.cni.es/guias/guias-series-ccn-stic.html>.

Fisher, Dennis (2013, 23 de abril). «Qué es un botnet» [artículo en línea]. *Karpersy Daily*. <https://www.kaspersky.es/blog/que-es-un-botnet/755/>.

Grigonis, Richard (2009). «Microsoft's $5,000,000 Reward for the Conficker Worm Creators» [artículo en línea]. *TMCnews*. TMCnet. <http://technews.tmcnet.com/ipcommunications/topics/ip-communications/articles/50562-microsofts-5000000-reward-the-conficker-worm-creators.htm>.

INCIBE (2018). *Problemas de seguridad en los procesadores de varios fabricantes* [avisos de seguridad en línea]. Madrid: Instituto Nacional de Ciberseguridad.

INCIBE-CERT (2013). «Mercado legal de vulnerabilidades 0day» [artículo en línea]. Madrid: Instituto Nacional de Ciberseguridad.

INTECO (2013). *Identificación y reporte de incidentes de seguridad para operadores estratégicos. Guía básica de protección de infraestructuras críticas*. Madrid: Instituto Nacional de Tecnologías de la Comunicación (INTECO).

Mossos d'Esquadra (2017, 31 de octubre). «Estafa suplantació d'un alt directiu o proveïdors d'empresa» [artículo en línea]. <https://mossos.gencat.cat/ca/detalls/Article/avis_ceocall

Navarro Arribas, Guillermo (2018). *Introducció a les vulnerabilitats* [módulo didáctico], PID_00255340. Barcelona: UOC.

Nightwatchcyber (2018, 29 de agosto). «Sensitive Data Exposure via WiFi Broadcasts in Android OS [CVE-2018-9489]» [artículo en línea]. Nigthwatch Cibersecurity. <https://wwws.nightwatchcybersecurity.com/2018/08/29/sensitive-data-exposure-via-wifi-broadcasts-in-android-os-cve-2018-9489/>.

Perekalin, Alex (2019, 14 de mayo). «Una llamada en WhatsApp basta para que te espíen» [artículo en línea]. *Karpersy Daily*. <https://www.kaspersky.es/blog/whatsapp-call-zero-day/18429/>.

Páginas web

Instituto Nacional de Ciberseguridad (INCIBE): <https://www.incibe.es/>.

Forum of Incident Response and Security Teams (FIRST): <https://www.first.org/>.

Kaspersky: <https://www.kaspersky.es/>.

MITRE: <https://cve.mitre.org/>.

National Vulnerability Database (NVD): <https://nvd.nist.gov/>.

Open Web Application Security Project (OWASP): <https://owasp.org/>.

TF-CSIRT Trusted Introducer: <https://www.trusted-introducer.org/>.

Una al día: <https://unaaldia.hispasec.com>.